

**OpenIDX**

Sıfır Güven Erişim Platformu · Self-Host · Yerli

BANKACILIK & FİNANS · BDDK

BDDK'ya uyumlu, yerli, self-host kimlik ve ayrıcalıklı erişim platformu.

OpenIDX; bankaların, sigorta ve aracı kurumların **kimlik doğrulama (SSO/MFA)**, **ayrıcalıklı erişim yönetimi (PAM)**, **yetkilendirme yönetimi (IGA)** ve **sıfır-güven ağ (ZTNA)** ihtiyacını — **Bankaların Bilgi Sistemleri ve Elektronik Bankacılık Hizmetleri Hakkında Yönetmelik** (RG 31069, 15 Mart 2020) ile tam uyumlu şekilde — kurumun kendi altyapısında, tek platformda karşılar.

Yönetmelik; erişim kontrolü, yetkili (privileged) erişim yönetimi, kapsamlı log kaydı, düzenli sızma testi ve birincil sistemlerin yurt içinde bulundurulmasını zorunlu kılar.

— BDDK Bankaların Bilgi Sistemleri ve Elektronik Bankacılık Hizmetleri Hakkında Yönetmelik. Kimlik doğrulama ve ayrıcalıklı erişim, bu yükümlülüklerin merkezindedir; yurt dışı SaaS IdP bu çerçevede kullanılamaz.

Yurt dışı SaaS kimlik sağlayıcısı bankacılıkta neden kullanılamaz?

✗ Okta · Microsoft Entra · Auth0 (yurt dışı SaaS)

- Müşteri + personel kimlik verisi yurt dışı veri merkezinde işlenir
- Birincil sistem / veri yerleştirme kuralına aykırı
- Dış hizmet alımı yükümlülükleri (BDDK dış-kaynak) karşılanamaz
- Ayrıcalıklı oturum kaydı ve denetim izi sağlayıcı kontrolünde
- Kesinti/erişim yabancı sağlayıcıya bağımlı, kur riskli lisans

✓ OpenIDX (yerli, self-host)

- Tüm kimlik/oturum verisi bankanın kendi veri merkezinde
- Birincil sistem yurt içinde, veri lokalizasyonu sağlanır
- Dış-kaynak yerine kurum-içi kontrol; kaynak kod denetlenebilir
- Ayrıcalıklı oturum kaydı, HMAC hash-zincirli değişmez denetim izi
- Sabit altyapı maliyeti; kullanıcı-başı ceza yok, kilitlenme yok

BDDK uyum haritası — madde madde karşılık

YÖNETMELİK GEREKLİLİĞİ	OPENIDX İLE KARŞILIK
Erişim kontrolü & kimlik doğrulama	Merkezi SSO (OIDC/SAML), çok-faktörlü doğrulama (passkey/TOTP/push), en-az-yetki, izin (AD/LDAP) entegrasyonu.
Yetkili (privileged) erişim yönetimi	PAM: şifreli kasa, otomatik parola rotasyonu, SSH/RDP/VNC brokeri, sunucu-tarafı kimlik enjeksiyonu (yönetici parolayı görmez).
Kapsamlı log / izlenebilirlik	HMAC hash-zincirli, kurcalama-belirtir denetim günlüğü; ayrıcalıklı oturum kaydı + transkript; SIEM'e akış.
Görevler ayrılığı & yetki gözden geçirme	SoD (önleyici, fail-closed), periyodik erişim sertifikasyon kampanyaları, geçici yetki (JIT) + otomatik iptal.
Veri yerleştirme / birincil sistem	Tamamen self-host; tek PostgreSQL, banka altyapısında. Veri yurt dışına çıkmaz.
Sızma testi & süreklilik	Pentest destekli sertifikasyon; otomatik yedekleme + test edilmiş geri yükleme; HA/DR.
Olay bildirimi & izleme	Adaptif risk motoru, anomali tespiti, kill-switch (token → oturum → ağ ≤30 sn).

%100

veri yurt içinde

4 → 1

dört ürün tek platform

%90+

CyberArk'a göre PAM tasarrufu

≤30 sn

uçtan uca erişim iptali

Bankaya ne sağlar? — dört sütun tek platform

KİMLİK & SSO (IAM)

- Personel + şube + genel müdürlük tek oturum açma (OIDC/SAML)
- Güçlü MFA: passkey, mobil push, TOTP, OTP; adaptif risk
- Mevcut AD/LDAP dizini ile senkron; harici IdP federasyonu
- İşe alım/ayırılma (JML) → otomatik hesap açma/kapama

YÖNETİŞİM (IGA)

- Periyodik yetki gözden geçirme (BDDK denetim kanıtı)
- Görevler ayrılığı — çakışan yetkiyi önler (front/back office)
- Geçici yetki (JIT) — proje/denetim için süreli erişim

AYRICALIKLI ERİŞİM (PAM)

BDDK KRİTİK

- Sunucu / veritabanı / ağ cihazı parolaları şifreli kasada
- Otomatik rotasyon: SSH, AWS, GCP, Postgres, MySQL, LDAP
- SSH/RDP/VNC oturumları tarayıcıdan, tam kayıt altında
- Yönetici parolayı hiç görmez; yasal saklama + süreli imha

SIFIR GÜVEN AĞ (ZTNA)

- Çekirdek bankacılık servisleri "karanlık" — açık port yok
- Uzaktan/tedarikçi erişimi VPN'siz, cihaz-sağlık kontrollü
- Ayrıcalıklı hedefler overlay üzerinde — saldırı yüzeyi minimal

Neden dört ayrı ürün yerine OpenIDX?

KLASİK YIĞIN (DÖRT SATICI)	OPENIDX (TEK PLATFORM)
Entra/Okta (IAM) + SailPoint (IGA) + CyberArk (PAM) + Zscaler (ZTNA) ayrı lisans, ayrı konnektör	IAM+IGA+PAM+ZTNA tek kod tabanı, tek PostgreSQL
Bir iptal kararı dört sistemde ayrı ayrı, konnektör gecikmeli	Tek kill-switch: token+oturum+kasa+ağ devresi ≤30 sn
Yığılmış kullanıcı-başı fatura \$33–65/kullanıcı/ay	Sabit altyapı; Enterprise ~\$4–6/kullanıcı/ay (%70–80 tasarruf)
Yabancı SaaS bağımlılığı, veri yurt dışında	Tam self-host, veri yurt içinde, açık kaynak (kilitleme yok)

Kurulum & devreye alma

- ✓ Bankanın kendi veri merkezine kurulum (Docker/Kubernetes, HA/DR)
- ✓ İlk uygulamalar 2–4 haftada SSO + MFA'ya bağlanır
- ✓ Denetim günlüğü + kurum SIEM'ine akış (BDDK log)
- ✓ Pentest → ISO 27001 hedefi + BDDK denetim hazırlığı
- ✓ Mevcut AD/LDAP + çekirdek sistem entegrasyonu
- ✓ Kritik sunucular PAM'e alınır, ayrıcalıklı oturum kaydı başlar
- ✓ Otomatik yedekleme + test edilmiş geri yükleme
- ✓ Yerinde eğitim + Türkçe destek + SLA

Uyum + egemenlik + maliyet — üçü birden.

BDDK Yönetmeliği'nin erişim/PAM/log/lokalizasyon yükümlülükleri tek platformda; müşteri ve personel verisi yurt içinde; ve dört yabancı lisans yerine sabit maliyetli yerli çözüm. Açık kaynak çekirdek bağımsız denetime açıktır.

Uyum notu: Bu broşür OpenIDX'in yeteneklerini ve ilgili BDDK yükümlülüklerinin gerekçesini özetler; nihai uyum değerlendirmesi bankanın bilgi sistemleri/iç denetim/hukuk birimleri tarafından yapılmalıdır. OpenIDX olgunluk seviyesi pilot/tasarım-ortağı için uygundur; üretim sertifikasyonu (ISO

